

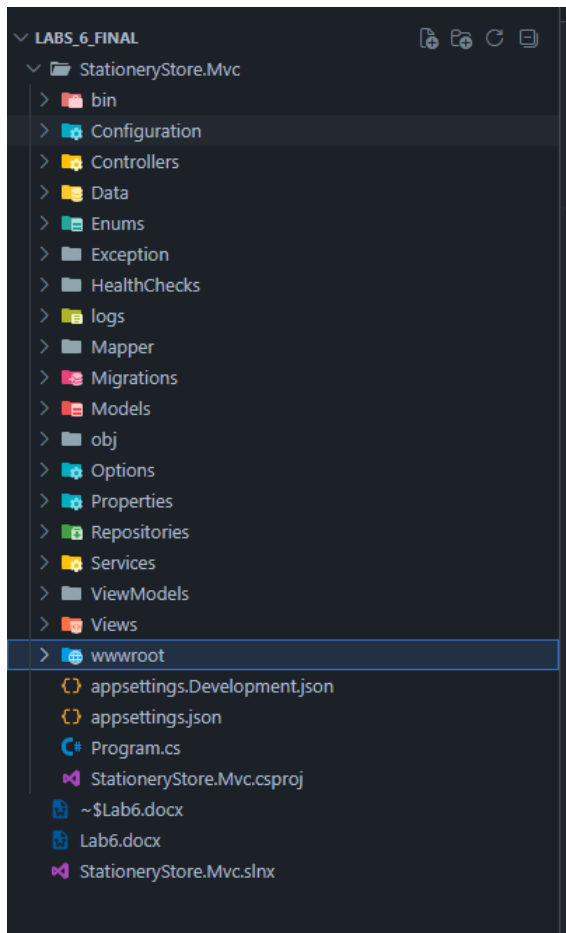
Link github:

https://github.com/tin1508/Asp.Net_TTH/tree/Lab06/Labs_6_Final

Câu 1: Mini Stationery Store Catalog MVC

Ứng dụng Stationery Store là hệ thống quản lý dữ liệu văn phòng phẩm, hỗ trợ quản lý danh mục (Category), sản phẩm (Stationery), và giỏ hàng (Cart). Hệ thống áp dụng đầy đủ các nhóm năng lực cốt lõi của ASP.NET Core MVC.

Kiến trúc Projects:



Ở ứng dụng Stationery Store này, em chia ra làm 2 role chính:

+ Admin (quản lý tất cả)

+ Customer (chỉ xem được stationery + thêm hàng vào giỏ + thanh toán)

Đầu tiên, với trang đăng nhập (Login):

Em có làm thêm 1 tính năng ngoài đăng nhập thông thường là đăng nhập bằng tài khoản Google (Oauth2)

Hoang's-MSSStore Stationeries Categories Privacy

Welcome back

Sign in to your Stationery Store Account

Continue with Google

OR

EMAIL ADDRESS

your_name@gmail.com

PASSWORD

Your password

Sign in

Don't have an account? [Create one](#)

Cách set up:

Em làm theo tuần tự từng bước theo link dưới đây và sau đó thì viết controller để xử lý các request đăng nhập:

<https://learn.microsoft.com/vi-vn/aspnet/core/security/authentication/social/google-logins?view=aspnetcore-9.0>

Nếu chưa có tài khoản thì có thể bấm vào nút Create One để tạo, sẽ có 1 form hiển thị để chúng ta điền các thông tin. Còn nếu muốn nhanh hơn (nếu chúng ta có tài khoản google thì dùng đăng nhập bằng google).

Hoang's-MSSStore Stationeries Categories Privacy Đăng nhập

FullName

Email

Password

ConfirmPassword

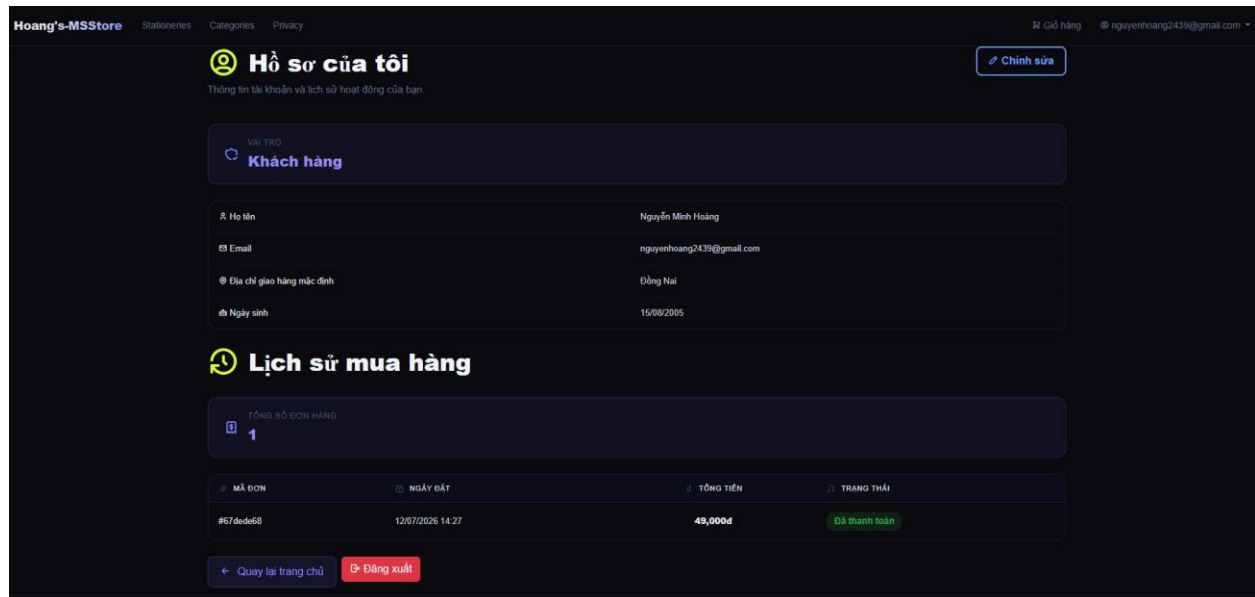
Register

Quay lại

© 2026 - StationeryStore.Mvc.ByHoangDev - Privacy

Em có làm thêm profile page users để chỉnh sửa các thông tin và theo dõi những đơn hàng đã mua đối với lại role customer:

Trang Profile phía customer:



Hồ sơ của tôi [Chỉnh sửa](#)

Thông tin tài khoản và lịch sử hoạt động của bạn.

Khách hàng

Thông tin cá nhân

Họ tên	Nguyễn Minh Hoàng
Email	nguyenhoang243@gmail.com
Địa chỉ giao hàng mặc định	Đồng Nai
Ngày sinh	15/08/2005

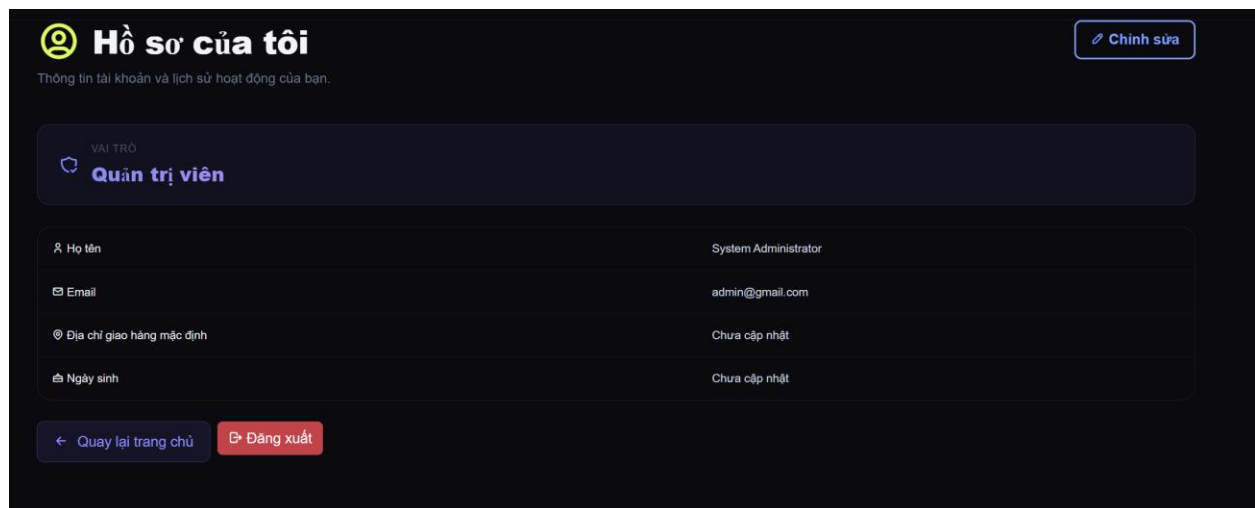
Lịch sử mua hàng

TỔNG SỐ ĐƠN HÀNG: 1

MÃ ĐƠN	NGÀY ĐẶT	TỔNG TIỀN	TRẠNG THÁI
#67dede68	12/07/2026 14:27	49,000đ	Đã thanh toán

[← Quay lại trang chủ](#) [Đăng xuất](#)

Trang Profile phía admin:



Hồ sơ của tôi [Chỉnh sửa](#)

Thông tin tài khoản và lịch sử hoạt động của bạn.

Quản trị viên

Thông tin cá nhân

Họ tên	System Administrator
Email	admin@gmail.com
Địa chỉ giao hàng mặc định	Chưa cập nhật
Ngày sinh	Chưa cập nhật

[← Quay lại trang chủ](#) [Đăng xuất](#)

Vì admin sẽ là người quản lý và website của em chủ yếu hoạt động online nên sẽ không có những quầy bán vật lý. Nên em sẽ không cấp chức năng tạo đơn hàng cho admin. Chỉ có Customer mới tạo đơn được thôi.

Ví dụ chúng ta sẽ thử chức năng chỉnh sửa ngày sinh và địa chỉ giao hàng của admin để test chức năng chỉnh sửa:



Chỉnh sửa hồ sơ

Cập nhật họ tên, địa chỉ giao hàng và ngày sinh của bạn.

Họ tên

System Administrator

Địa chỉ giao hàng mặc định

Nhập địa chỉ giao hàng

Ngày sinh

08/17/2005



✓ Lưu thay đổi

× Hủy

Kết quả:

Cập nhật hồ sơ thành công!



VAI TRÒ

Quản trị viên

👤 Họ tên

System Administrator

✉ Email

admin@gmail.com

📍 Địa chỉ giao hàng mặc định

Unknown

🎂 Ngày sinh

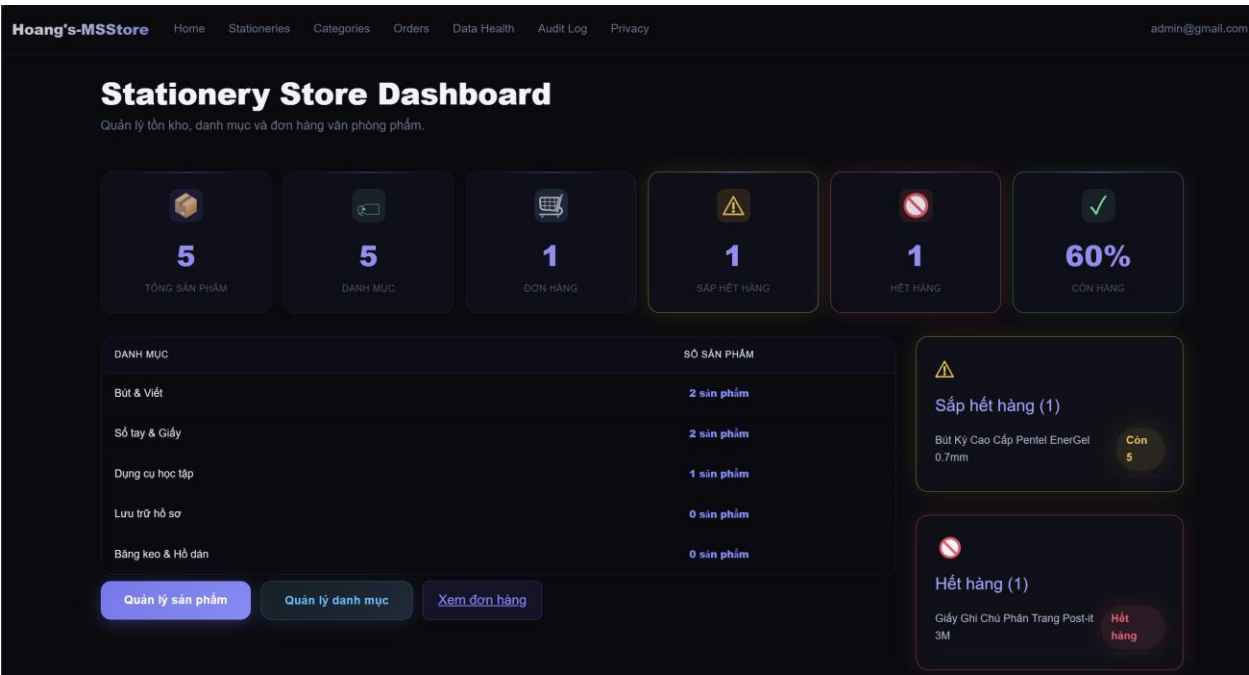
17/08/2005

← Quay lại trang chủ

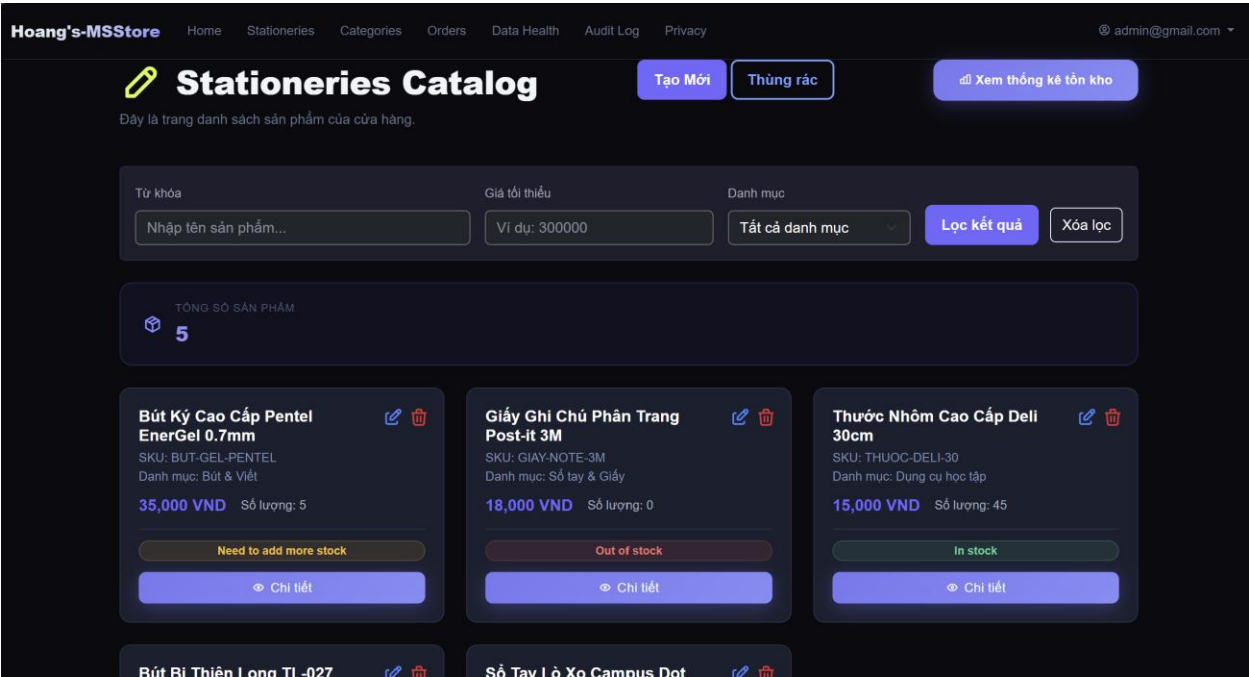
🚪 Đăng xuất

Phía Admin:

Trang Dashboard:



Trang quản lý các văn phòng phẩm:



Trang Tạo, sửa, xóa, thùng rác, và xem thống kê tồn kho:

Hoang's-MSStore

[Home](#)[Stationeries](#)[Categories](#)[Orders](#)[Data Health](#)[Audit Log](#)[Privacy](#)

admin@gmail.com

Tạo Văn Phòng Phẩm

Form POST dùng asp-for để bind dữ liệu vào StationeryCreateViewModel.

Quay lại danh sách

Mã sản phẩm

Vi dụ: NBK-A4-LND

Tên sản phẩm

Vi dụ: Blue BallPoint Pen

Danh mục

Vi dụ: Accessories

Nhà cung cấp

Vi dụ: EraserTech

Giá bán

0.00

Số lượng

1

Mức tồn tối thiểu

1

Lưu Sản phẩm

Quay lại

Model Binding từ Form POST

Khi bind Lưu, ASP.NET Core sẽ đọc các input trong form và tự map vào StationeryCreateViewModel.

Vi dụ input có `asp-for="Name"` thì dữ liệu sẽ được bind vào property `Name`.

Nếu tên input không khớp với property, action có thể nhận null hoặc giá trị mặc định.

Hoang's-MSStore

[Home](#)[Stationeries](#)[Categories](#)[Orders](#)[Data Health](#)[Audit Log](#)[Privacy](#)

admin@gmail.com

Chỉnh sửa Văn Phòng Phẩm

Quay lại danh sách

Mã sản phẩm

THUOC-DELI-30

Tên sản phẩm

Thước Nhôm Cao Cấp Deli 30cm

Danh Mục

Dụng cụ học tập

Nhà cung cấp

Deli Việt Nam

Giá bán

15000.00

Số lượng

45

Mức tồn tối thiểu

10

Lưu Sản phẩm

Quay lại

Với action xóa thì khi ta xóa sẽ hiển thị pop up để xác nhận:

localhost:5147 says

Bạn có chắc chắn muốn xóa Thước Nhôm Cao Cấp Deli 30cm

OK

Cancel

Giá tối thiểu

Danh mục

Vi dụ: 300000

Tất cả danh mục

Xóa xong thì nó sẽ xuất hiện trong thùng rác:

Stationery Trash

Các văn phòng phẩm đã bị xóa.

Quay lại danh sách

ID	SKU	TÊN SẢN PHẨM	THỜI GIAN XÓA	THAO TÁC
5	THUOC-DELI-30	Thước Nhôm Cao Cấp Deli 30cm	12/07/2026 22:51	Khôi phục

Nếu muốn khôi phục thì chỉ cần bấm nút khôi phục là được:

Đã Khôi Phục Văn Phòng Phẩm Thành Công.

ID	SKU	TÊN SẢN PHẨM	THỜI GIAN XÓA	THAO TÁC
Không có sản phẩm nào trong thùng rác.				

Giấy Ghi Chú Phân Trang Post-it 3M

SKU: GIAY-NOTE-3M

Danh mục: Sổ tay & Giấy

18,000 VND

Số lượng: 0

Out of stock

Chi tiết

Bút Bì Thiên Long TL-027 (Màu Xanh)

SKU: BUT-BI-TL027

Danh mục: Bút & Viết

4,000 VND

Số lượng: 149

In stock

Chi tiết

Sổ Tay Lò Xo Campus Dot Grid A5

SKU: SO-DOT-CAMPUS

Danh mục: Sổ tay & Giấy

45,000 VND

Số lượng: 79

In stock

Chi tiết

Bút Kỳ Cao Cấp Pentel EnerGel 0.7mm

SKU: BUT-GEL-PENTEL

Danh mục: Bút & Viết

35,000 VND

Số lượng: 15

In stock

Chi tiết

Thước Nhôm Cao Cấp Deli 30cm

SKU: THUOC-DELI-30

Danh mục: Dụng cụ học tập

15,000 VND

Số lượng: 45

In stock

Chi tiết

Trang xem thông kê tồn kho, giá trị của tổng các sản phẩm:

Hoang's-MSSStore

HomeStationeriesCategoriesOrdersData HealthAudit LogPrivacy

admin@gmail.com

Stationery Stats

Trang này giúp bạn xem nhanh tổng quan tình hình tồn kho của cửa hàng.

Quay lại danh sách

5

TỔNG SỐ LOẠI SẢN PHẨM

288

TỔNG SỐ LƯỢNG TỒN KHO

5,351,000 VND

TỔNG GIÁ TRỊ TỒN KHO

1

SẢN PHẨM ĐÃ HẾT HÀNG

0

SẢN PHẨM CẦN NHẬP THÊM

Đánh giá tình hình tồn kho

Có sản phẩm đã hết hàng. Cần kiểm tra và nhập thêm sớm.

Tổng số loại sản phẩm

5

Tổng số lượng tồn kho

288

Tổng giá trị tồn kho

5,351,000 VND

Số sản phẩm đã hết hàng

1

Số sản phẩm cần nhập thêm

0

© 2026 - StationeryStore.Mvc ByHoangDev - Privacy

Trang xem các danh mục của cửa hàng:

Hoang's-MSStore

[Home](#)[Stationeries](#)[Categories](#)[Orders](#)[Data Health](#)[Audit Log](#)[Privacy](#)

admin@gmail.com

Category Catalog

Đây là trang danh sách danh mục sản phẩm của cửa hàng.

Tìm Kiếm

Tạo Mới

TỔNG SỐ DANH MỤC SẢN PHẨM

5

TÊN NHÓM	SỐ LƯỢNG SẢN PHẨM	CHI TIẾT
Bút & Viết	2	Xem
Sổ tay & Giấy	2	Xem
Dụng cụ học tập	1	Xem
Lưu trữ hồ sơ	0	Xem
Băng keo & Hồ dán	0	Xem

← Quay lại trang chủ

© 2026 - StationeryStore.Mvc.ByHoangDev - Privacy

Tạo mới danh mục:

Hoang's-MSStore

[Home](#)[Stationeries](#)[Categories](#)[Orders](#)[Data Health](#)[Audit Log](#)[Privacy](#)

admin@gmail.com

Tạo Danh Mục Văn Phòng Phẩm

Form POST dùng asp-for để bind dữ liệu vào CategoryCreateViewModel.

Quay lại danh sách

Tên danh mục văn phòng phẩm

Ví dụ: Blue BallPoint Pen

Lưu

Quay lại

Model Binding từ Form POST

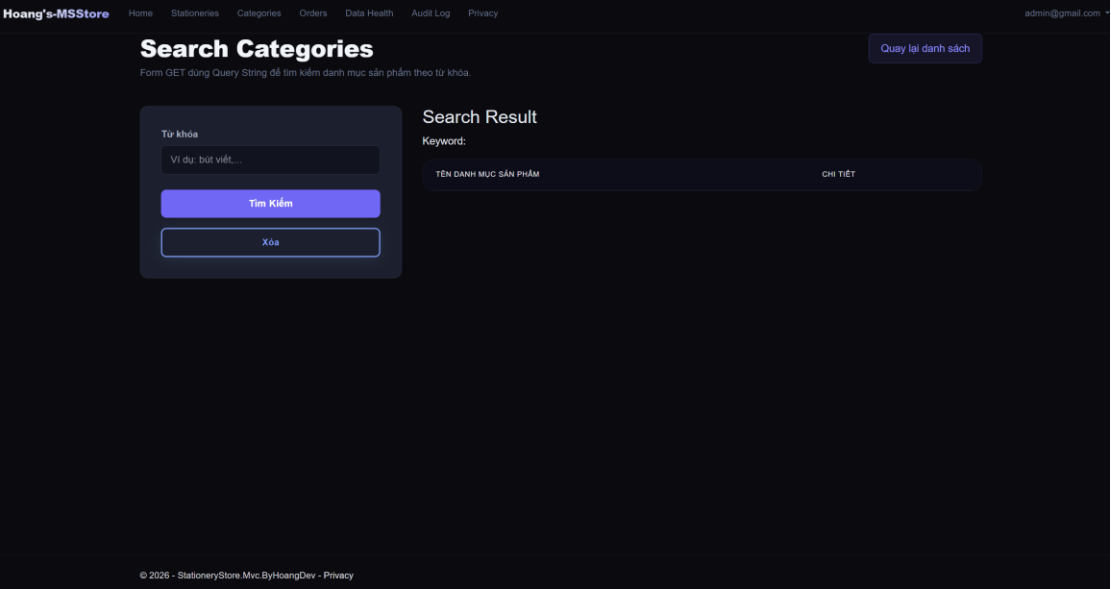
Khi bấm Lưu, ASP.NET Core sẽ đọc các input trong form và tự map vào CategoryCreateViewModel.

Ví dụ input có `asp-for="Name"` thì dữ liệu sẽ được bind vào property **Name**.

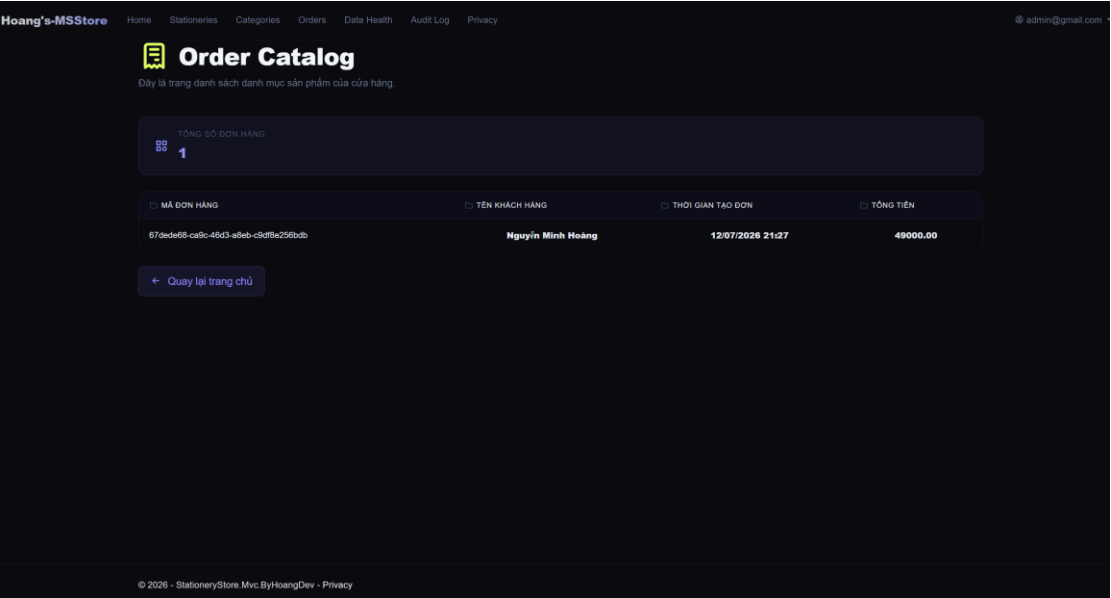
Nếu tên input không khớp với property, action có thể nhận null hoặc giá trị mặc định.

© 2026 - StationeryStore.Mvc.ByHoangDev - Privacy

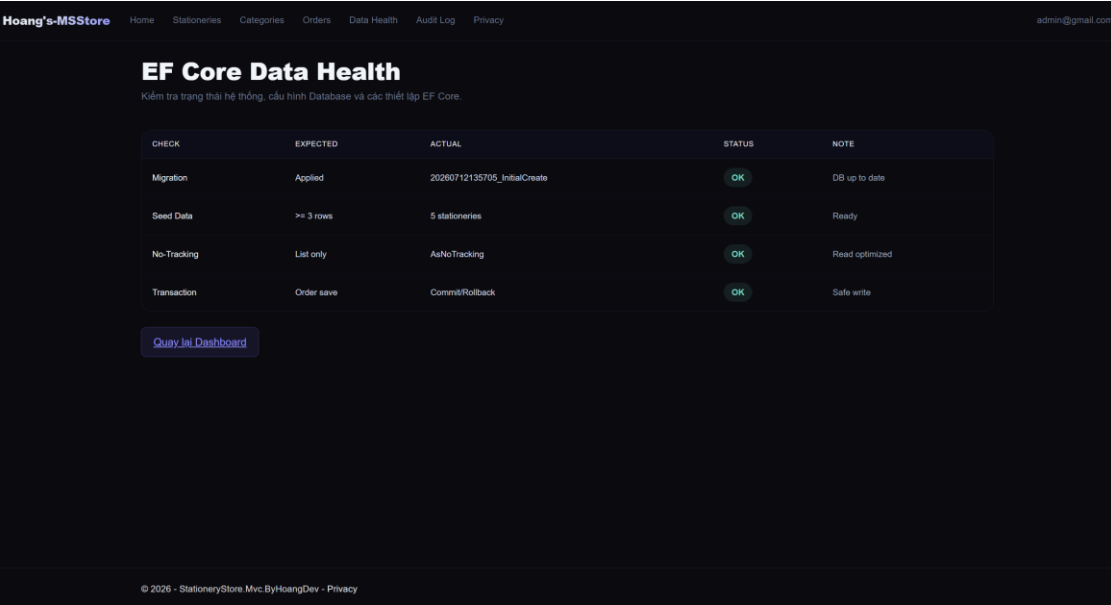
Tìm kiếm danh mục theo từ khóa:



Trang xem các đơn hàng:



Trang theo dõi data health:



Trang theo dõi các Logs:

Hoang's-MSSore

HomeStationeriesCategoriesOrdersData HealthAudit LogPrivacy

admin@gmail.com

Audit Logs

TIME	USER	ACTION	ENTITY	ENTITYID	RESULT	IP
2026-07-12 21:51:43	nguyenhoang150805@gmail.com	Login	Authentication	nguyenhoang150805@gmail.com	Success	::1
2026-07-12 21:51:22	System / Guest	Register	Authentication	nguyenhoang150805@gmail.com	Success	::1
2026-07-12 21:48:03	nhathoai123@gmail.com	Login	Authentication	nhathoai123@gmail.com	Success	::1
2026-07-12 21:42:18	nhathoai123@gmail.com	Login	Authentication	nhathoai123@gmail.com	Success	::1
2026-07-12 21:41:04	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:40:29	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:38:57	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:38:50	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:38:41	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:36:06	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:34:39	System / Guest	Login	Authentication	nk123@gmail.com	Failure	::1
2026-07-12 21:29:46	System / Guest	Register	Authentication	nhathoai123@gmail.com	Success	::1
2026-07-12 21:08:08	admin@gmail.com	Login	Authentication	admin@gmail.com	Success	::1
2026-07-12 21:05:02	admin@gmail.com	Create	Stationery	0	Success	::1
2026-07-12 21:04:14	admin@gmail.com	Create	Stationery	0	Success	::1

Đây là tất cả các chức năng của admin

Phía Customer:

Riêng đối với Customer, thì chỉ có danh sách các sản phẩm và danh sách các danh mục, chứ không có những trang khác như Home, Datahealth, AuditLogs, ... như phía admin.

Đây là trang danh sách sản phẩm, mỗi sản phẩm sẽ có 2 chức năng là sẽ mua ngay và thêm vào giỏ hàng phòng trường hợp customer mua nhiều sản phẩm.

Hoang's-MSSore

StationeriesCategoriesPrivacy

Giỏ hàngnguyenhoang2439@gmail.com

Stationeries Catalog

Đây là trang danh sách sản phẩm của cửa hàng

Tìm kiếm

Giá từ thấp

Danh mục

Nhập từ sản phẩm

Ví dụ: 300000

Tắt cả danh mục

Lọc kết quả

Xóa lọc

5

Đã lọc 5 sản phẩm

Giấy Ghi Chú Phấn Trang Post-it 3M

SKU: GAVY-NOTE-3M

Danh mục: Sổ tay & Giấy

18,000 VND

Số lượng: 0

Thêm vào giỏ

Chi tiết

Đặt hàng

Bút Bì Thiên Long TL-027 (Màu Xanh)

SKU: BUT-BI-TL-027

Danh mục: Bút & Vở

4,000 VND

Số lượng: 149

Thêm vào giỏ

Chi tiết

Mua ngay

Sổ Tay Lò Xo Campus Dot Grid A5

SKU: SO-DOT-CAMPUS

Danh mục: Sổ tay & Giấy

46,000 VND

Số lượng: 79

Thêm vào giỏ

Chi tiết

Mua ngay

Bút Ký Cao Cấp Pentel EnerGel 0.7mm

SKU: BUT-GEL-PENTEL

Danh mục: Bút & Vở

35,000 VND

Số lượng: 15

Thêm vào giỏ

Chi tiết

Mua ngay

Thước Nhôm Cao Cấp Deli 30cm

SKU: THUC-DELI-30

Danh mục: Dụng cụ học tập

15,000 VND

Số lượng: 45

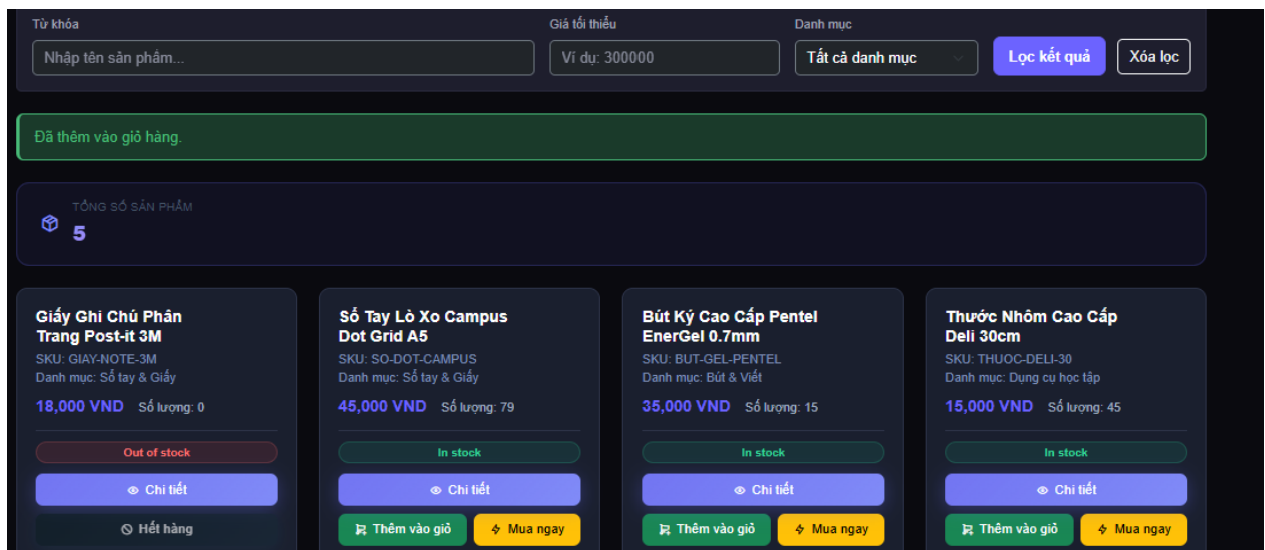
Thêm vào giỏ

Chi tiết

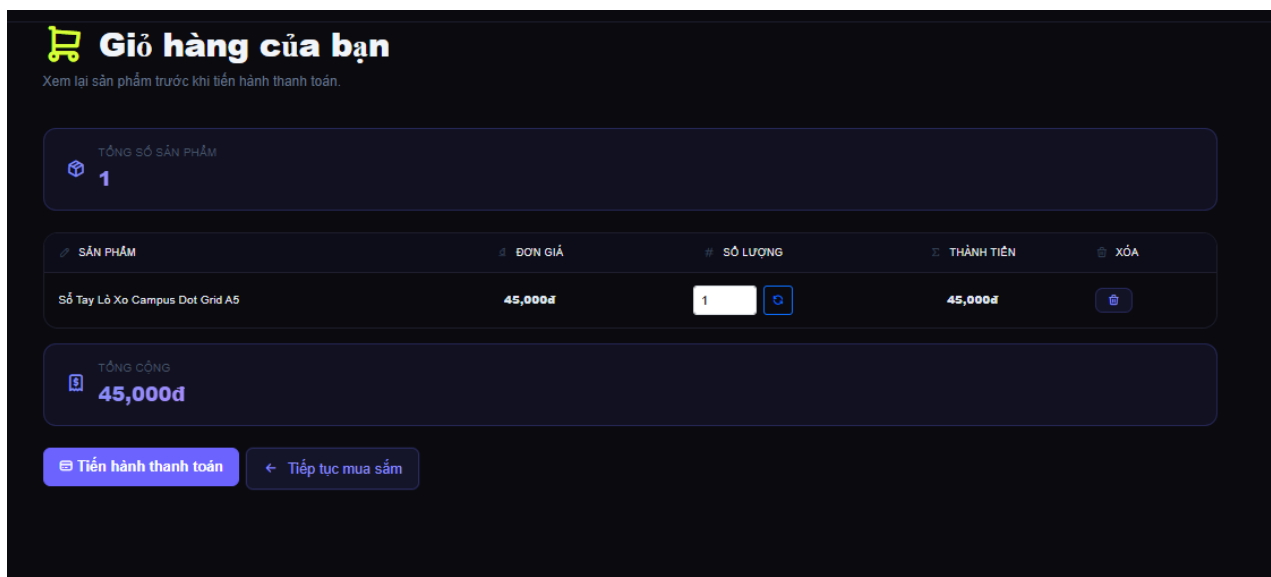
Mua ngay

© 2026 - StationeryStore-Mvc-BYHoangDev - Privacy

Sau khi bấm nút thêm vào giỏ hàng:

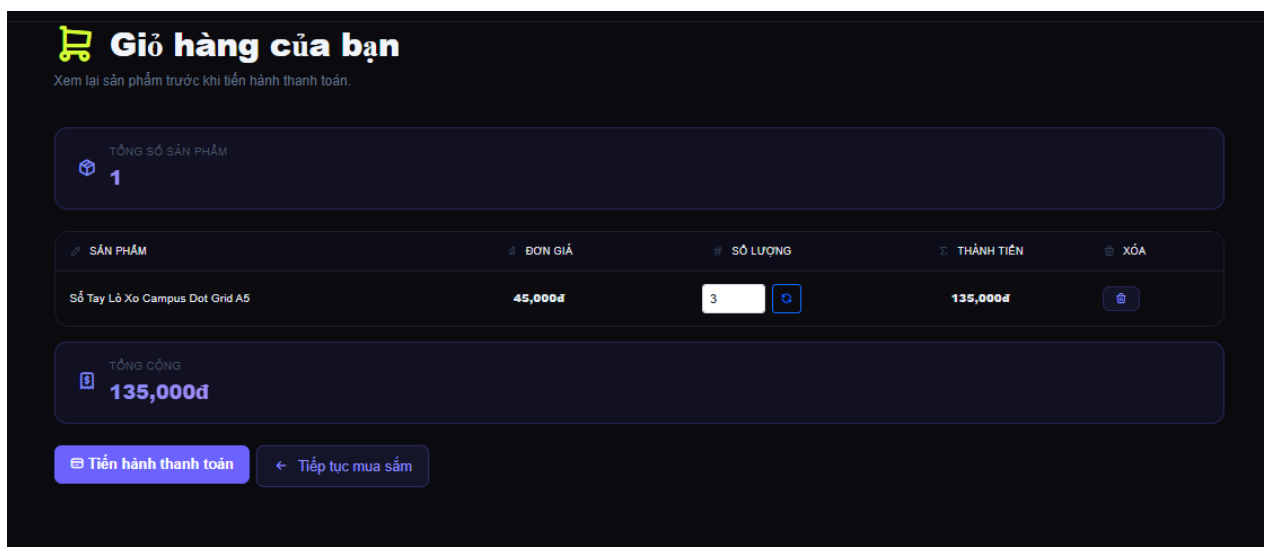


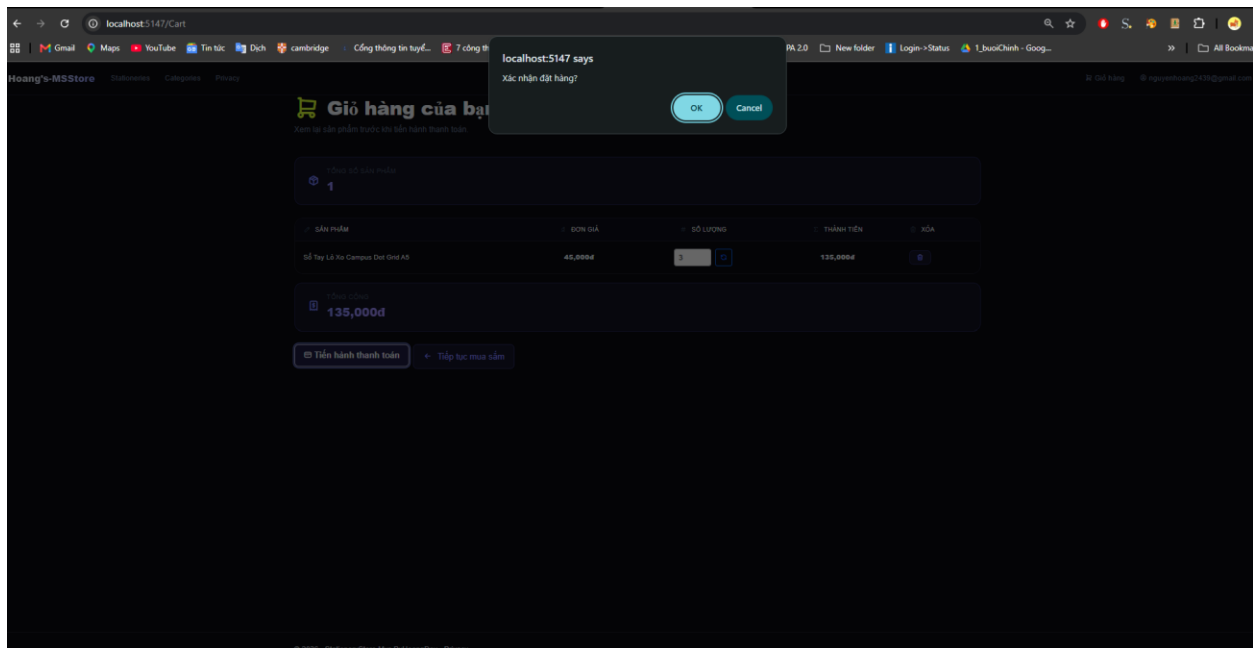
Ta sẽ kiểm tra giỏ hàng:



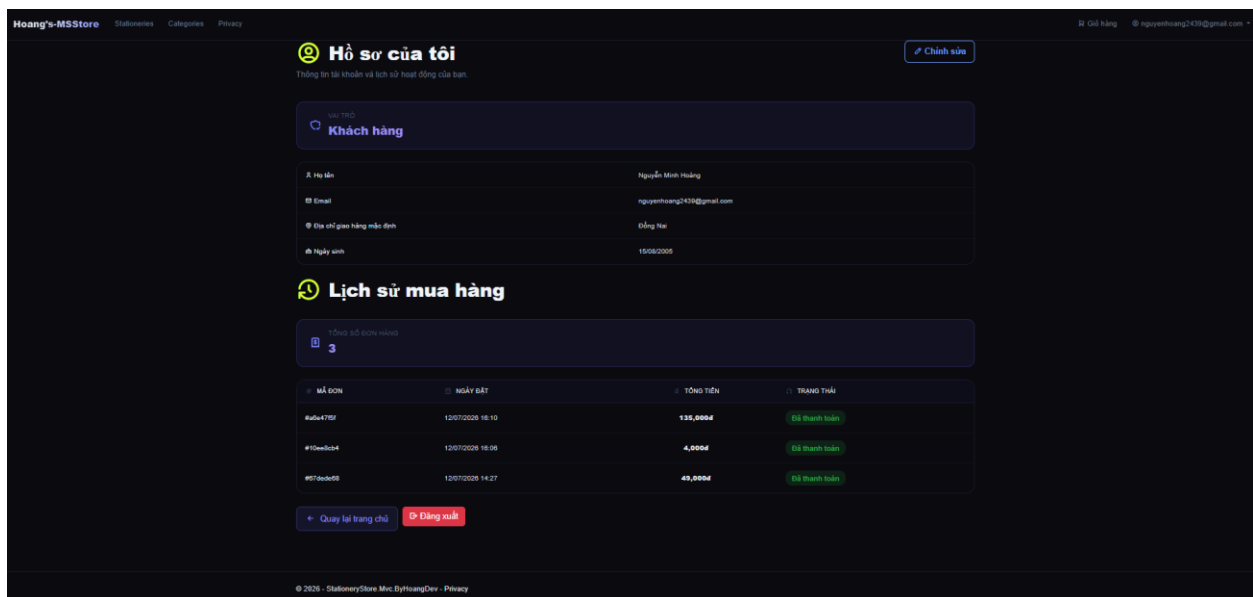
Ở đây, hệ thống sẽ cho phép chúng ta cập nhập số lượng sản phẩm mà chúng ta muốn mua

Ví dụ: ở đây, ta chọn 3 và bấm nút kế bên số lượng thì hệ thống sẽ tự động tính tổng tiền cần phải thanh toán cho chúng ta.



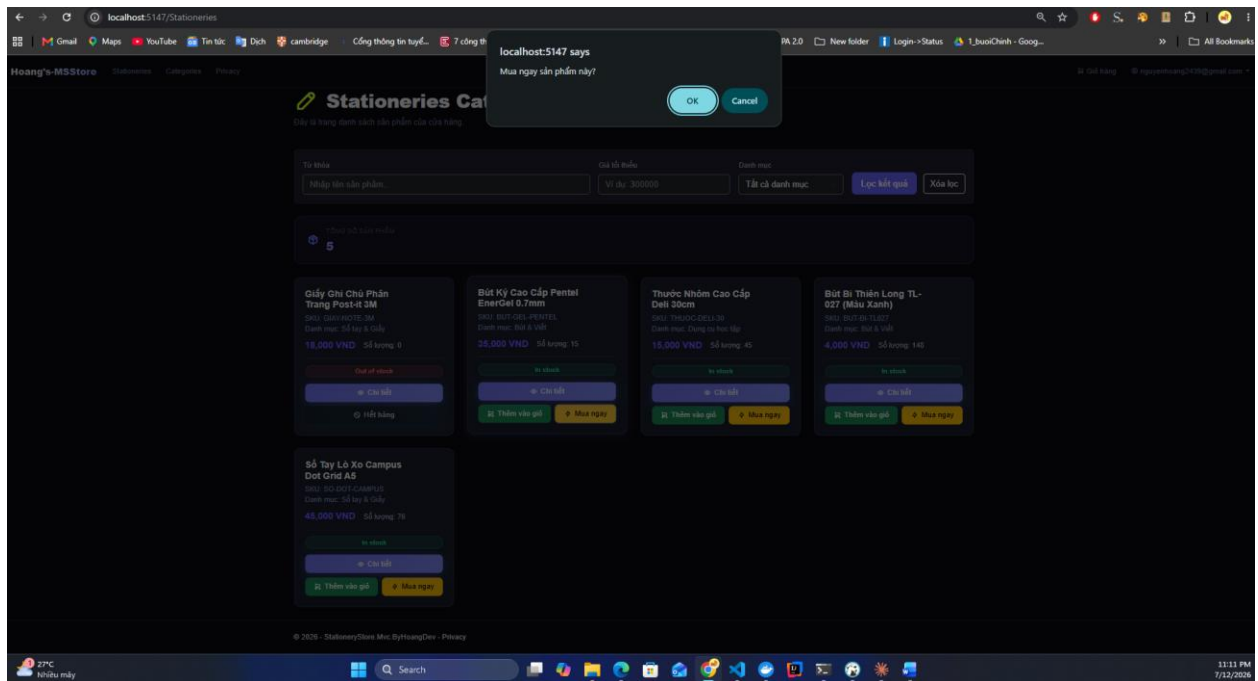


Sau khi ta bấm nút tiến hành thanh toán, thì hệ thống sẽ alert 1 thông báo để chúng ta xác nhận. Sau khi xác nhận, hệ thống sẽ chuyển chúng ta về profile để xem đơn hàng.

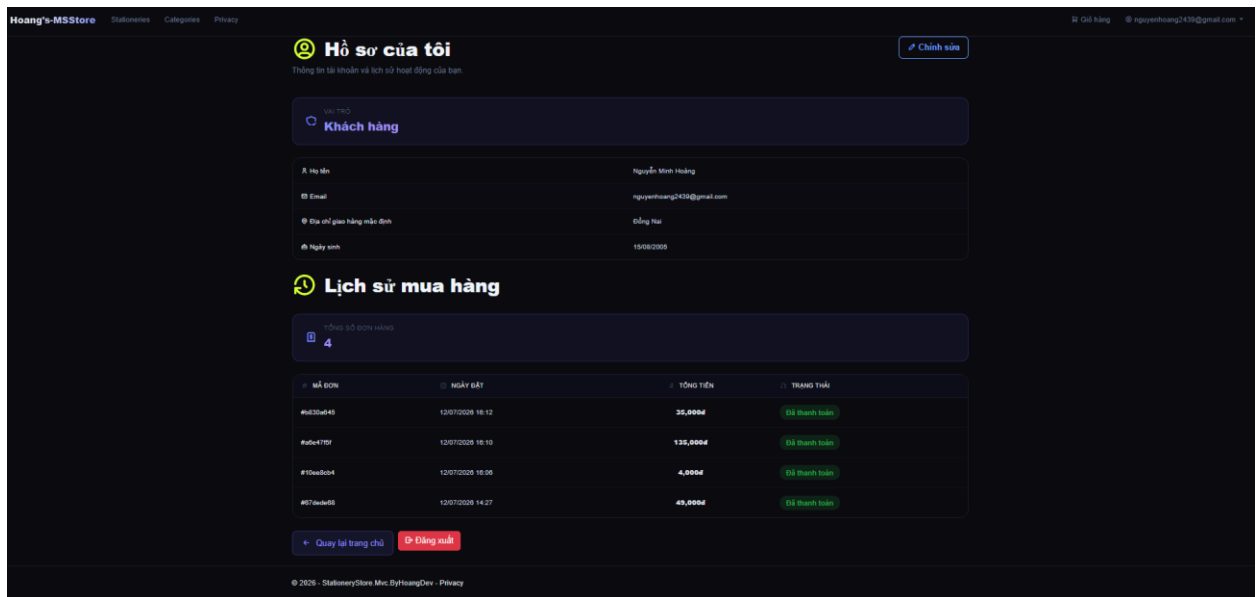


Với trường hợp mua ngay thì chúng ta sẽ có những bước như sau:

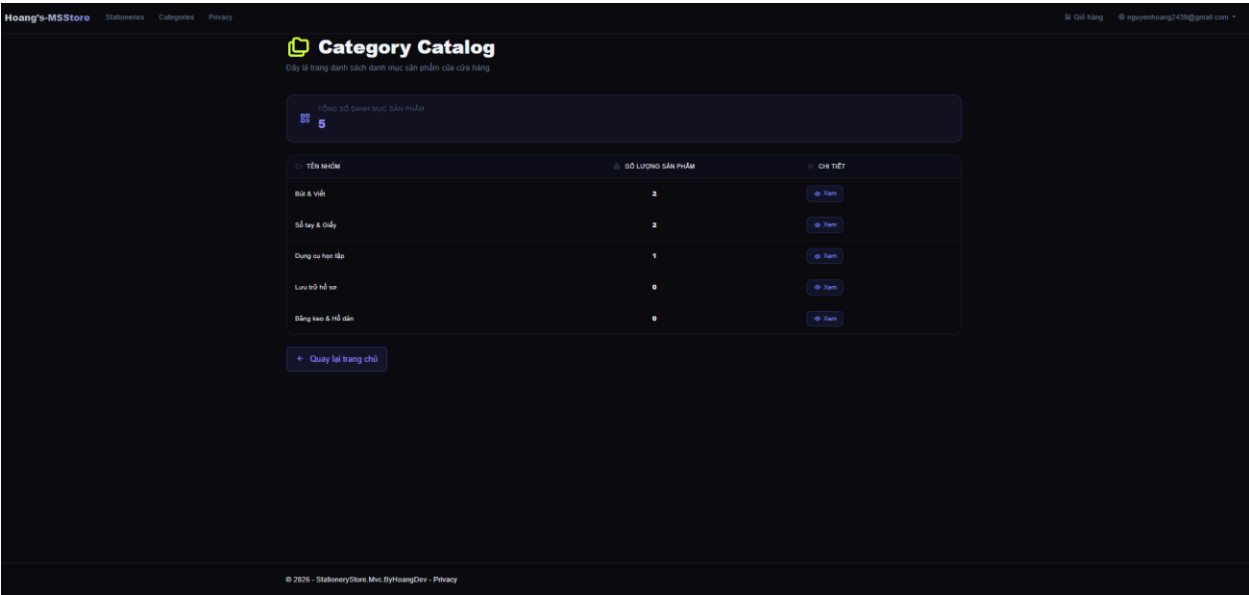
Hệ thống cũng sẽ alert ra 1 thông báo để chúng ta xác nhận.



Sau khi xác nhận thành công:



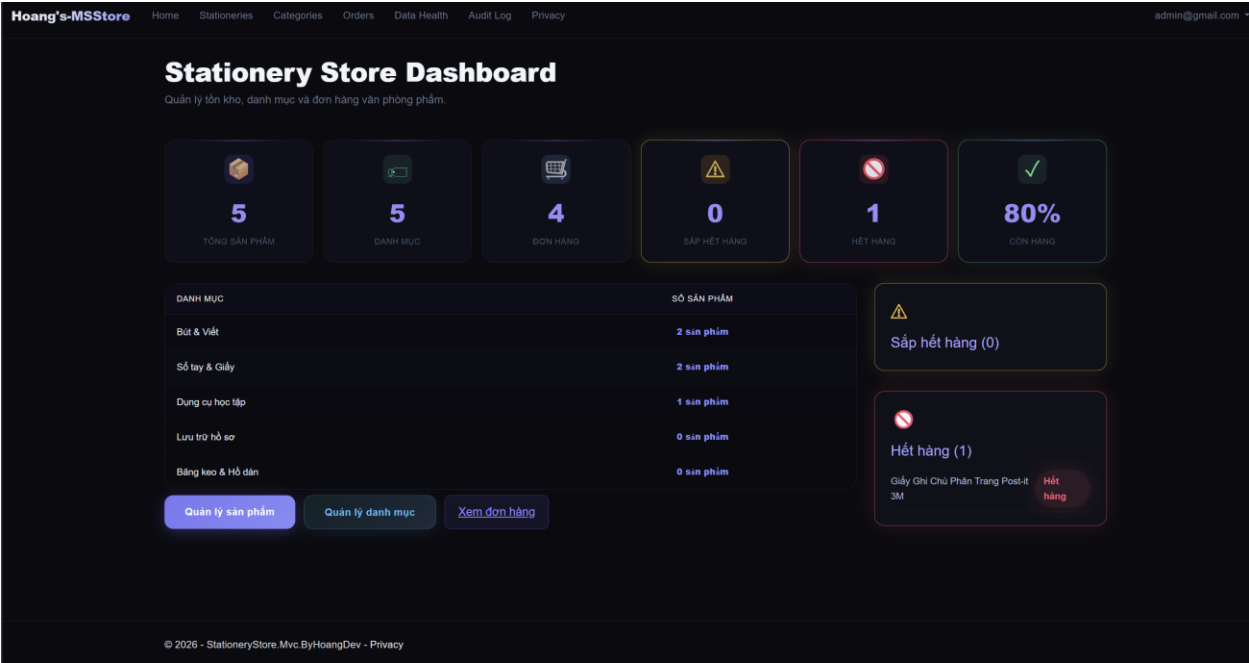
Đây là trang Category ở phía người dùng (không thể tạo mới cho category được, vì chỉ có admin mới có quyền đó thôi).



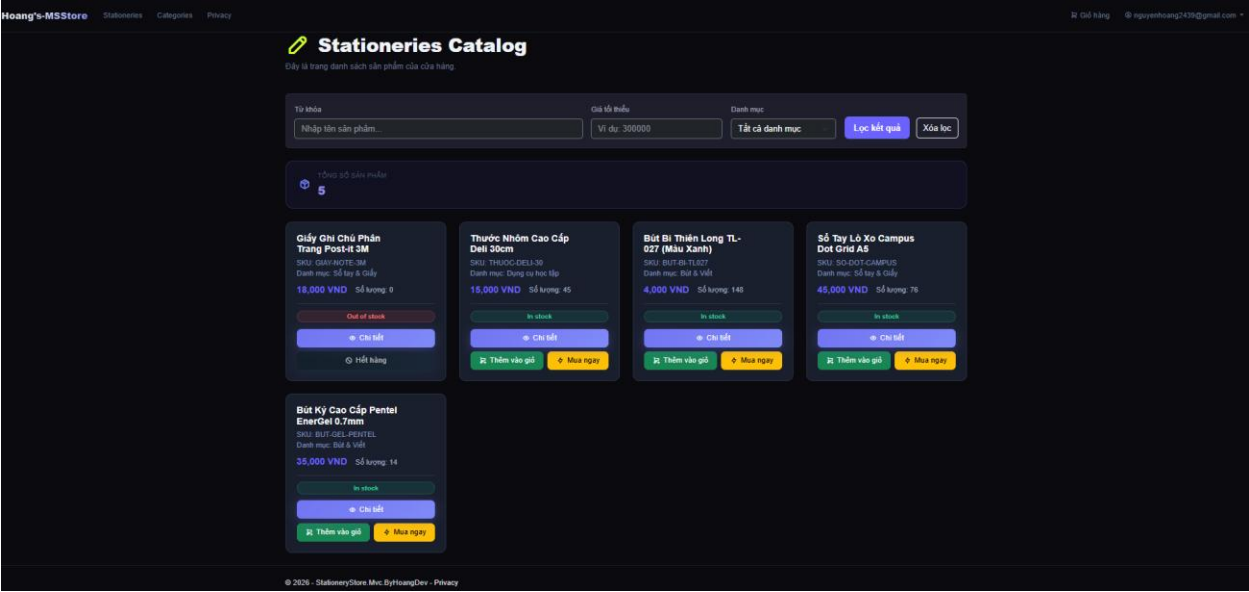
Câu 2:

- **Feature 1 — Tách quyền quản lý giá và quyền quản lý tồn kho**

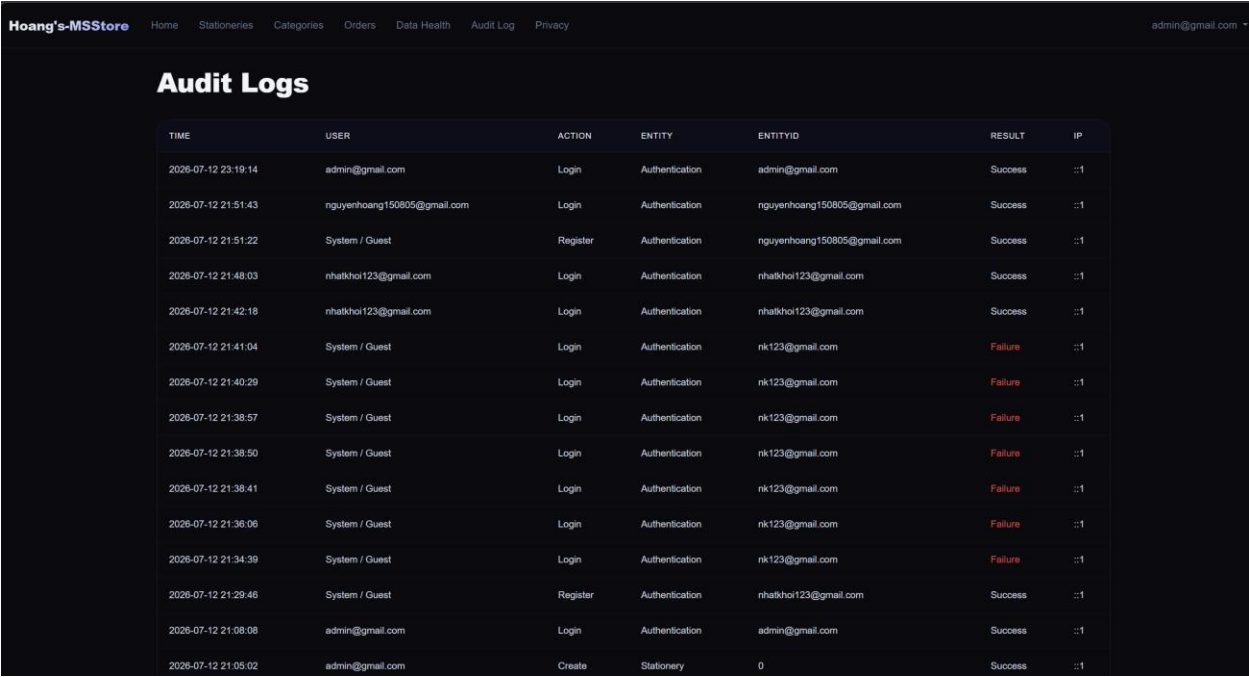
Như ta có thể thấy ở phía admin có đầy đủ các chức năng để quản lý tồn kho:



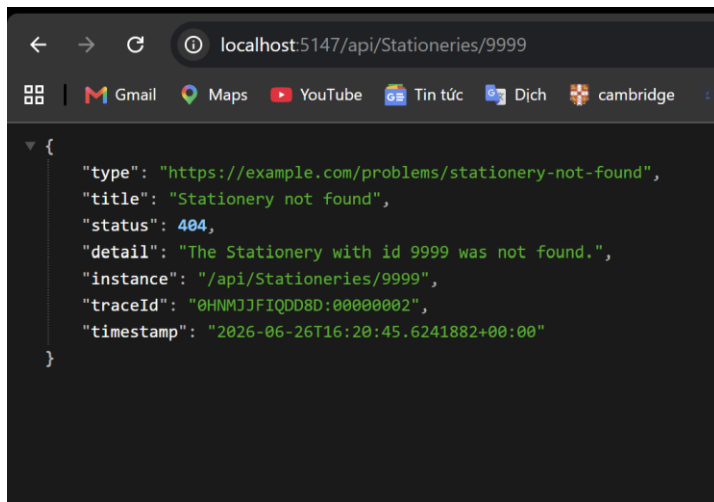
Ở phía customer thì chỉ có xem lựa sản phẩm và thanh toán:



- Feature 2 — Thay ảnh sản phẩm an toàn
- Feature 3 — Audit Log Search và Security Dashboard



- Feature khuyến khích — API Search có ValidationProblemDetails



```
{
  "type": "https://example.com/problems/stationery-not-found",
  "title": "Stationery not found",
  "status": 404,
  "detail": "The Stationery with id 9999 was not found.",
  "instance": "/api/Stationeries/9999",
  "traceId": "0HNMJJFIQDD8D:00000002",
  "timestamp": "2026-06-26T16:20:45.6241882+00:00"
}
```

Câu 3:

1. Vì sao không được lưu password dạng plain text? ASP.NET Core Identity giúp giảm rủi ro này như thế nào?

Vì nếu lưu plain text khiến toàn bộ password tài khoản bị lộ nếu database bị tấn công. ASP.NET Core Identity sử dụng thuật toán băm (Hashing) phức tạp kèm Salt ngẫu nhiên, khiến hacker dù lấy được database cũng không thể giải mã ra mật khẩu gốc.

2. Sau khi login thành công, vì sao user chuyển sang trang khác vẫn được nhận diện? Cookie authentication tham gia vào luồng này như thế nào?

Khi đăng nhập thành công, máy chủ sẽ tạo ra một chuỗi mã hóa (Authentication Ticket) và gửi về trình duyệt dưới dạng Cookie. Các request tiếp theo, trình duyệt tự động đính kèm Cookie này. Middleware của ASP.NET Core sẽ giải mã Cookie để nhận diện ApplicationUser mà không cần truy vấn lại database liên tục.

3. Ấn nút Create/Edit/Delete trên giao diện có đủ bảo mật không? Vì sao vẫn phải bảo vệ route/action ở server bằng [Authorize] hoặc policy?

Không đủ bảo mật vì kẻ tấn công có thể dễ dàng lấy URL của chức năng Edit và dùng công cụ như Postman, Swagger để gửi POST request trực tiếp. Bắt buộc phải dùng [Authorize(Roles="Admin")] ở Server để hệ thống từ chối mọi request không hợp lệ ngay tại Controller.

4. Hãy phân biệt Authentication và Authorization bằng một tình huống cụ thể.

- Authentication (Xác thực): Xác định coi mình là ai, ví dụ: User nhập đúng admin@gmail.com và password để hệ thống biết đây là ai đang đăng nhập.
- Authorization (Phân quyền): Xác định coi mình làm được gì, ví dụ: Hệ thống biết là tôi, và biết tôi mang role Customer nên sẽ bị chặn lại khi cố vào trang CreateNewStationery.

5. Khi nào nên dùng Role trực tiếp và khi nào nên dùng Policy?

Dùng Role ([Authorize(Roles="Admin")]) cho các phân quyền lớn, quản trị toàn trang. Dùng Policy (CanAdjustStock) cho các nghiệp vụ vi mô, cần kết hợp nhiều điều kiện (VD: Chỉ Staff thuộc phòng kho mới được sửa tồn kho).

6. Nếu Staff gõ trực tiếp URL /Products/Create nhưng action không có [Authorize], rủi ro gì xảy ra?

Lỗi hồng Forced Browsing. Staff (thậm chí Anonymous) có thể tạo ra các sản phẩm rác, phá hoại dữ liệu hệ thống mà không bị ngăn chặn.

7. Vì sao Logout nên dùng POST thay vì GET? Anti-forgery token bảo vệ thao tác này như thế nào?

Nếu dùng GET, kẻ xấu có thể lừa user click vào một thẻ ẩn chứa link GET /Logout, khiến user bị văng khỏi hệ thống ngoài ý muốn. Dùng POST kèm Anti-forgery token đảm bảo lệnh đăng xuất phải chủ đích xuất phát từ chính form trên giao diện của trang web.

8. CSRF có thể lợi dụng cookie login của user bằng cách nào? Vì sao form POST có anti-forgery token sẽ an toàn hơn?

Cookie tự động đính kèm vào request nếu user truy cập tên miền đích. Kẻ xấu tạo một form POST giả trên trang web xấu và dụ user ấn Submit, mượn luôn quyền (Cookie) của user để xóa dữ liệu. Anti-forgery token sinh ra một mã độc nhất ở Server và View; trang web xấu không thể biết mã này, nên request giả mạo sẽ bị Server từ chối (HTTP 400).

9. Nếu action có [ValidateAntiForgeryToken] nhưng View dùng form HTML viết tay không sinh token, kết quả là gì?

Hệ thống sẽ quăng lỗi HTTP 400 Bad Request hoặc Antiforgery token validation failed.

10. Vì sao @Model.Name an toàn hơn @Html.Raw(Model.Name)? Payload XSS minh họa:

@Model mặc định mã hóa các ký tự đặc biệt (VD: < thành <). Nếu dùng Html.Raw, thẻ HTML sẽ được thực thi.

Payload: Kẻ gian nhập tên sản phẩm là <script>alert('Bị hack!');</script>. Nếu dùng Html.Raw, mọi user vào xem danh sách sản phẩm đều bị chạy đoạn script này.

11. SQL Injection xảy ra như thế nào nếu nối chuỗi SQL? LINQ thay đổi rủi ro này ra sao?

Nối chuỗi: SELECT * FROM Stationeries WHERE Name = ' + keyword + '. Nếu keyword là ' OR 1=1 --, câu lệnh biến thành in ra toàn bộ database. EF Core và LINQ ngầm định sử dụng Parameterized Query, biến nội dung user nhập thành một "giá trị" (value) chứ không phải là một phần của câu lệnh SQL, loại bỏ hoàn toàn rủi ro này.

12. Vì sao không tin FileName, extension hoặc Content-Type? SVG chứa script gây rủi ro gì?

Client có thể dễ dàng dùng Burp Suite để đổi tên virus.exe thành avatar.png.exe hoặc giả mạo Content-Type. Nếu tải file SVG chứa mã JS độc hại (<script>), khi user khác mở ảnh đó lên trình duyệt, mã JS sẽ chạy (Stored XSS) và đánh cắp cookie.

13. Trong tính năng thay ảnh, vì sao chỉ xóa ảnh cũ sau khi file mới và DB đã cập nhật thành công?

Để đảm bảo tính toàn vẹn của dữ liệu. Vì nếu ta xóa ảnh cũ trước, sau đó hàm SaveChanges() lưu database thất bại, hệ thống sẽ rơi vào trạng thái "Database còn đường dẫn ảnh cũ, nhưng file vật lý đã bị xóa" sẽ gây ra lỗi giao diện và làm mất dữ liệu.

14. Application log và Audit log khác nhau thế nào?

- App Log: Phục vụ Dev/Ops (ghi lỗi Exception, 500, thời gian query).
- Audit Log: Phục vụ Security/Nghiệp vụ (ghi vết ai, làm gì, lúc nào).
- Ví dụ: Hàm lấy danh sách Stationery lỗi kết nối thì ghi App Log; thao tác DeleteStationery thành công thì bắt buộc ghi Audit Log.

15. Nếu user bị AccessDenied nhiều lần, nên ghi lại gì để truy vết?

Ghi lại: UserId (nếu đã login), IP Address, thời gian (Timestamp), URL cố tình truy cập (/Stationeries/Delete), và User-Agent. Tuyệt đối không lưu mật khẩu hoặc Cookie Token.

16. Khác biệt giữa /health/live và /health/ready khi DB mất kết nối?

- /health/live: Vẫn trả về 200 OK (vì process ASP.NET Kestrel vẫn đang chạy bình thường).
- /health/ready: Trả về 503 Service Unavailable (báo cho Load Balancer biết app chưa sẵn sàng nhận request vì DB đang sập).

17. Nếu API trả lỗi 500, ProblemDetails nên và không nên chứa gì?

- Nên chứa: Type, Title (Internal Server Error), Status (500), TraceId (để dev tra cứu log).
- Không được chứa: Stack trace, Connection String, Exception Message chi tiết (kẻ gian sẽ biết hệ thống dùng thư viện gì để khai thác).

18. Nếu Service tự new Repository bên trong method, khó khăn gì khi test?

Vi phạm nguyên lý Dependency Inversion. Code bị "dính chặt" (tight-coupling) vào database thật. Khi viết Unit Test, không thể đưa Mock Repository vào để test độc lập logic của Service.

19. Tạo Order thành công nhưng trừ Stock thất bại. Transaction giải quyết thế nào?

Dữ liệu sẽ bị sai lệch (bán hàng nhưng kho không giảm). Transaction gom 2 thao tác thành một khối (Atomicity). Nếu thao tác trừ Stock thất bại, Transaction sẽ tự động Rollback lại việc tạo Order, đảm bảo tính nhất quán của CSDL.

20. RowVersion giúp phát hiện lỗi Last Save Wins thế nào?

Hai Admin cùng mở trang Edit Bút bi. Admin A lưu giá 5000đ, RowVersion đổi từ 1 thành 2. Admin B (màn hình vẫn giữ RowVersion=1) bấm lưu giá 4000đ. EF Core so sánh thấy 1 != 2 dưới database nên quăng lỗi DbUpdateConcurrencyException, chặn Admin B ghi đè công sức của Admin A.

21. Dùng global query filter IsDeleted=false, khi nào cần IgnoreQueryFilters()?

Cần dùng ở chức năng Thùng rác (Trash) hoặc khi Restore. Nếu lạm dụng sai chỗ hoặc quên bật lại filter, admin có thể vô tình làm lộ các dữ liệu nhạy cảm đã bị ẩn khỏi hệ thống cho end-user xem.

22. Thứ tự truy vết khi user báo lỗi chức năng:

1. Dùng TraceId hiển thị trên màn hình lỗi của user.

2. Tra Application Log bằng TraceId để tìm dòng Exception.
3. Nếu là lỗi quyền, tra Audit Log xem bị chặn bởi Role/Policy nào.
4. Check Health Check xem các dịch vụ phụ thuộc có sống không.

23. Kiểm tra code AI sinh cho Identity/Upload file:

- Kiểm tra thuật toán Hash (đảm bảo AI không code plain-text).
- Kiểm tra Validate file (có chặn định dạng lạ, có quét dung lượng không).
- Kiểm tra việc gán tên file có dùng GUID không.
- Đảm bảo không rò rỉ secret key/connection string trong code AI cung cấp.